

Unrestricted Resource Consumption

Introduction

What is Unrestricted Resource Consumption?

Unrestricted Resource Consumption occurs when APIs lack limits on user requests, allowing excessive consumption of CPU, memory, bandwidth, or storage. This vulnerability leads to service degradation, denial of service (DoS), and increased operational costs. It is commonly caused by inadequate rate limiting, lack of input validation, and missing quotas, often enabling attackers to overwhelm systems.

What is the impact of this issue ?

- **Increased costs:** These attacks can lead to increased costs for the API provider, as additional resources may be required to handle the excessive load.
- **Service disruptions:** These attacks can affect the availability and performance of the API, causing delays and disruptions for legitimate users.
- **Unexpected bills:** If the API relies on third-party services such as SMS messaging APIs, the attacks can result in unexpected bills and potential service restrictions.

What are the common causes for Unrestricted Resource Consumption?

- Lack of proper input validation and sanitization
 - Failing to validate and sanitize inputs can result in unexpected behaviors, leading to resource-intensive operations and potential security vulnerabilities.
- Inefficient code or algorithm design
 - Poorly optimized code or inefficient algorithms can lead to excessive resource usage, causing performance bottlenecks and system instability.

Case Study

A popular e-commerce platform exposes an API endpoint to allow users to add items to their shopping cart, such as [/api/v1/cart/add_item](#)

The api endpoint accepts a JSON payload containing **product_id** and the **quantity** to add.

The Vulnerability

Unrestricted Resource Consumption is the vulnerability here. The API lacks proper limits or validation on the **quantity** field. A legitimate user is only expected to add a small number of items but the system allows any integer value up to the maximum limit of the integer data type.

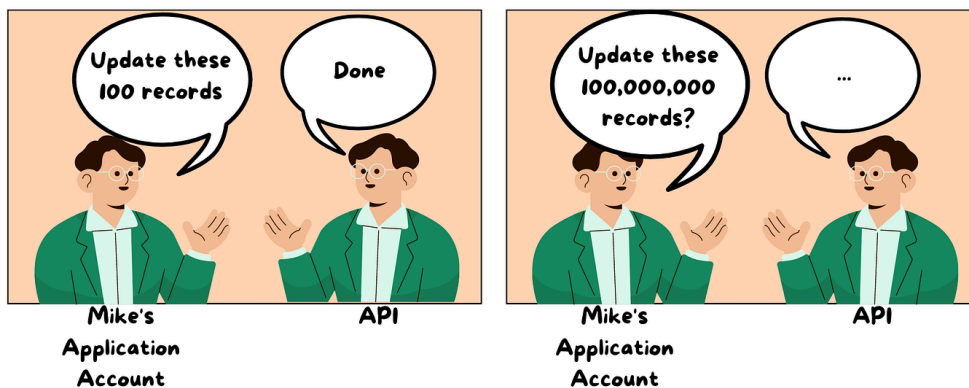
The Attack

An attacker discovers this lock of restriction and sends a single request to the API with an extremely high quantity for a single product. I.e

quantity: 2147483647

Results

Once the attack is done, the server has no choice but to accept the absurdly large value. The server tries to add the items to the shopping cart which results in heavy consumption of resources such as RAM and CPU effectively causing a DOS attack.



Mitigations

- Define clear abuse policies.
- Monitor and analyze traffic/response.
- Define limits on server resources that API users can consume.

Conclusion

Unrestricted Resource Consumption is a common vulnerability arising from the lack of proper limits on user requests to an API. As demonstrated by the e-commerce case study, this oversight can be easily exploited by an attacker to consume excessive resources like CPU and RAM, resulting in severe impacts such as service disruptions, increased operational costs, unexpected bills, and a Denial of Service (DoS) attack.

In conclusion, implementing robust rate limiting, strict input validation, and resource quotas is necessary for maintaining system stability, ensuring service availability for legitimate users, and protecting the financial health of the API provider.

References

<https://www.akamai.com/glossary/what-is-unrestricted-resource-consumption>

<https://learn.snyk.io/lesson/unrestricted-resource-consumption/>